

Vulnerability Assessment Report

The e-commerce company stores information on a remote database server, since many of the employees work remotely from locations all around the world. Employees of the company regularly query, or request, data from the server to find potential customers. The database has been open to the public since the company's launch three years ago. As a newly hired cybersecurity professional, you recognize that keeping the database server open to the public is a serious vulnerability.

You are tasked with completing a vulnerability assessment of the situation to communicate the potential risks to decision makers at the company. You must create a written report that explains how the vulnerable server is a risk to business operations and how it can be secured.

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 2026 to August 2026. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

- The purpose of this vulnerability assessment is to identify security risks associated with the publicly accessible remote database server and evaluate their potential impact on business operations.
- The server stores potential customer information that is valuable to the organization and therefore requires appropriate access controls to protect its confidentiality and integrity.
- Unauthorized access or data exfiltration could result in loss of business information, regulatory consequences, and reputational damage.
- A successful Denial of service attack could also disrupt database availability and business continuity, resulting in financial losses.

Vulnerability Assessment Report

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
<i>External Threat Actor</i>	Exfiltration of confidential customer data	3	3	9
	Denial of Service	3	2	6
Likelihood x Severity= Risk				

Approach

The risk from each threat source is identified and compared with current security controls of the organization. A limitation of this assessment is that detailed information about firewall rules, authentication mechanisms, database configuration, logging, and network architecture was not provided; therefore, these controls should be validated during a technical assessment.

The detailed risk calculation method with supporting evidence is as follows as:

1. External Attacker

Type of Threat: Human

Risk assessment:

- The database server is publicly accessible, increasing its exposure to Internet attacks
- The MySQL service is intended to support authorized organizational access but is potentially reachable from untrusted external networks
- An external threat actor could attempt credential attacks, exploit vulnerabilities in the database service, or use compromised credentials to obtain unauthorized access
- Confidentiality of customer data and requirements may get compromised and that attracts regulatory scrutiny and penalty
- The organization may face reputation damage which affects new business opportunities and margins, since the organisation is in growing stage
- The primary impact is therefore **confidentiality**

Likelihood score is 3 because the database service is publicly accessible, allowing external threat actors to discover and directly target the exposed service.	Severity score is 3 due to the data stored in the server is of customer oriented
---	--

Vulnerability Assessment Report

2. External Attacker

Type of Threat: Human

Risk assessment:

- Because the database service is publicly reachable, external threat actor can potentially send large volumes of network traffic or service requests to the exposed system
- A DoS/DDoS attack can consume network bandwidth, CPU, memory, connection capacity, or application resources
- Resource exhaustion could make the database unavailable or degrade its performance.
- This could prevent legitimate remote employees from querying customer information and disrupt normal business operations
- The primary impact is therefore **availability**

Likelihood score is 3 due to since the ports and services are exposed	Severity score is 2 due to the limited organisation operation is affected
---	---

REMEDIATION

- With the vulnerability assessment conducted for the public server using [NIST SP 800-30 Rev. 1](#), the identified major threat source is external threat actor
- The assessment identified two primary threat events associated with the publicly exposed database service: unauthorized access and data exfiltration, and DoS/DDoS attacks.
- The Remediation for the threat is as follow as:
 - 1) The server should be in the private network of the organisation with a **private IP**, so that server shouldn't be reachable over internet at ease
 - 2) The **Defense in depth** layer with solutions such as **firewall** should be implemented with proper configuration in order to *control un-authorized access and service un-availability issues* at multiple layers
 - 3) **Network segmentation** should be implemented to restrict communication between the database server and other systems, reducing the potential impact of a compromised server and limiting lateral movement.

Vulnerability Assessment Report

- 4) Remote employees should be provided with **controlled access** in order to reduce attack surface. The use of **MFA** should be implemented for remote employees to *reduce the risk of unauthorized access* resulting from compromised credential.
- 5) Existing control involves use of TLS which *offers encrypted channel*.

CONCLUSION

The proposed assessment is conducted on available data and the remediation strategy involves primarily safeguarding the access to database server. The organisation should govern and review the security initiatives periodically to protect itself against the ever-expanding security threats.